Report attività: SQL Injection, Cracking Password e Attacco DoS

Introduzione

Durante questa esercitazione abbiamo lavorato su una macchina vulnerabile (Metasploitable) simulando alcune tecniche di attacco reali. In particolare abbiamo:

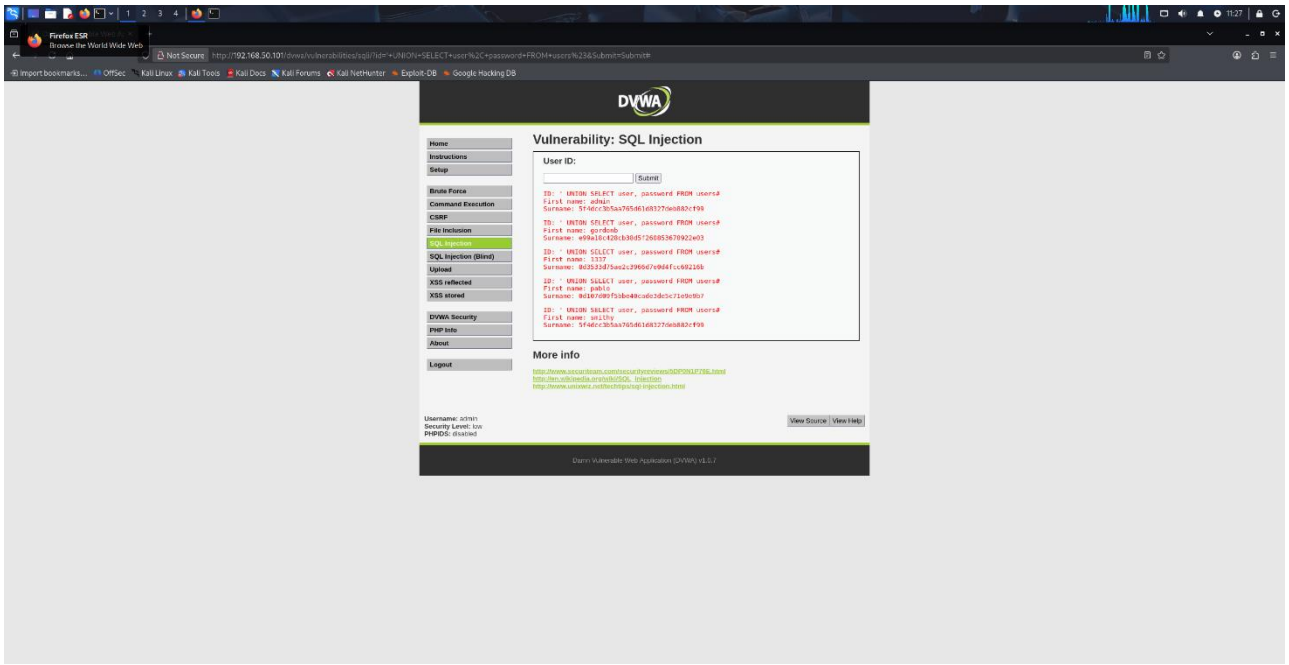
- recuperato password tramite SQL Injection
- analizzato gli hash trovati
- craccato le password con John the Ripper
- simulato un attacco DoS con Slowloris
- monitorato il comportamento del server durante l'attacco

Recupero e analisi delle password

Dopo aver sfruttato la SQL Injection, siamo riusciti a estrarre le password dal database. Tuttavia, queste non erano in chiaro ma sotto forma di hash MD5.

All'inizio sembravano stringhe casuali, ma confrontandole abbiamo capito che erano hash. Questo tipo di protezione oggi è considerato debole, perché:

- è molto veloce da calcolare
- non usa tecniche come il "salt"
- può essere facilmente attaccato con dizionari o rainbow table

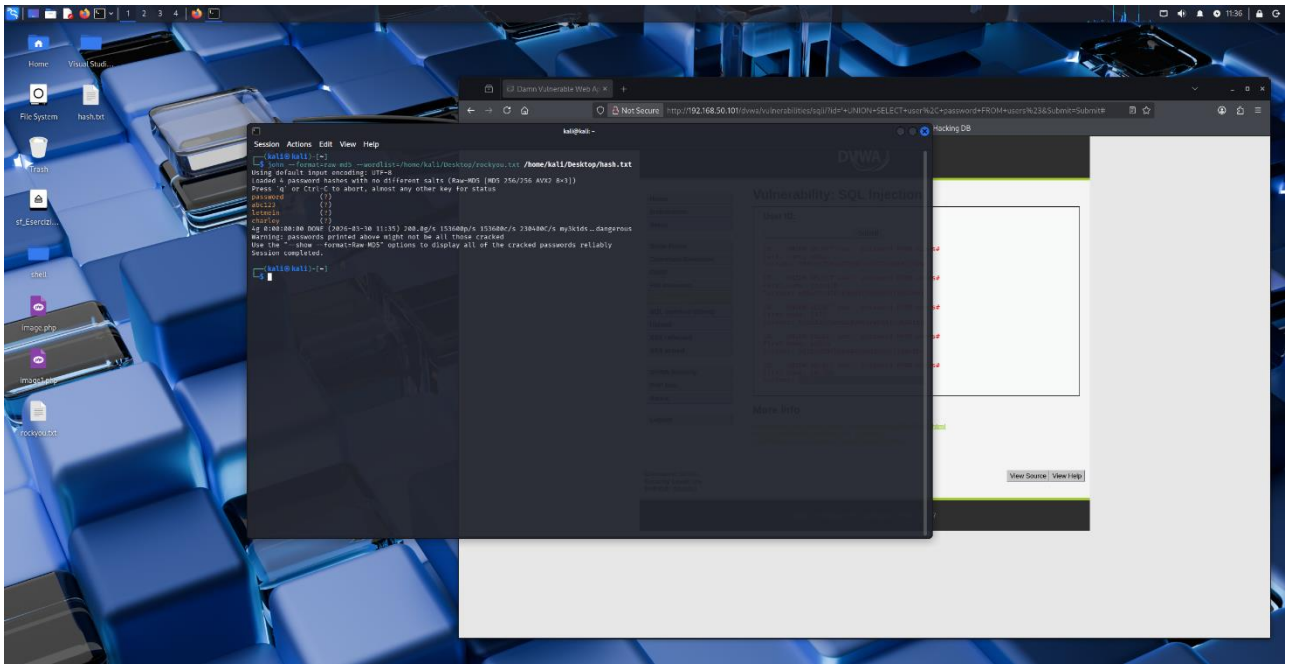


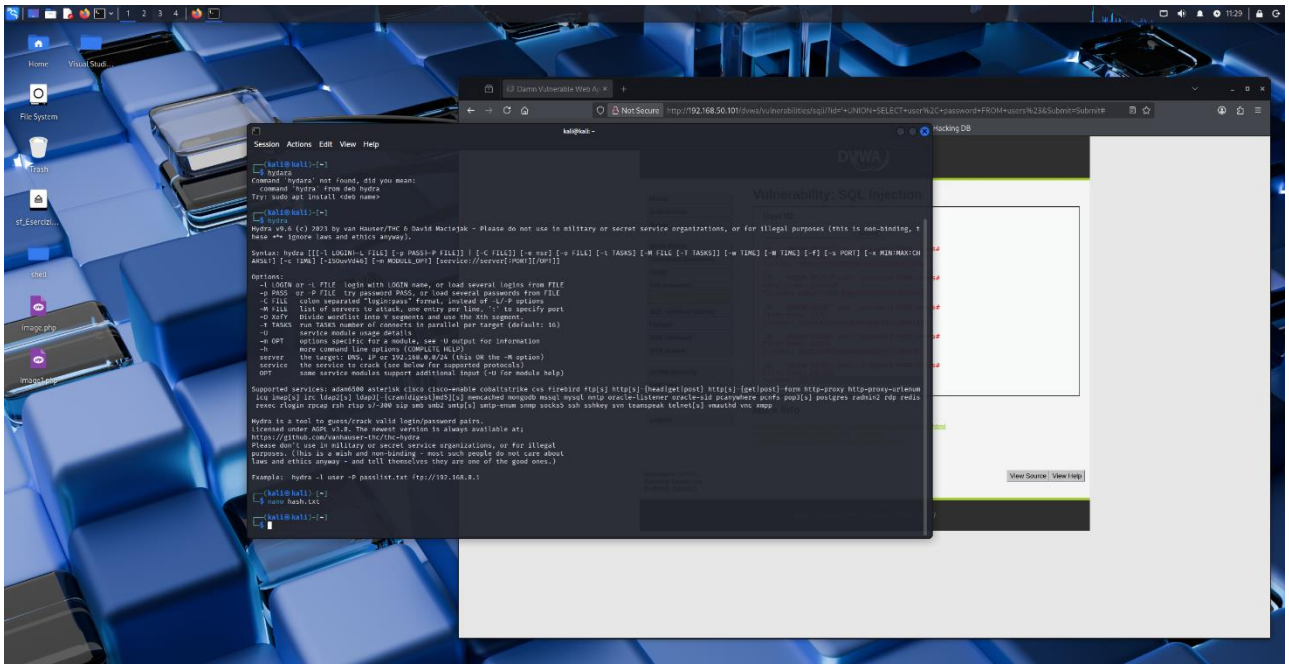
Cracking delle password

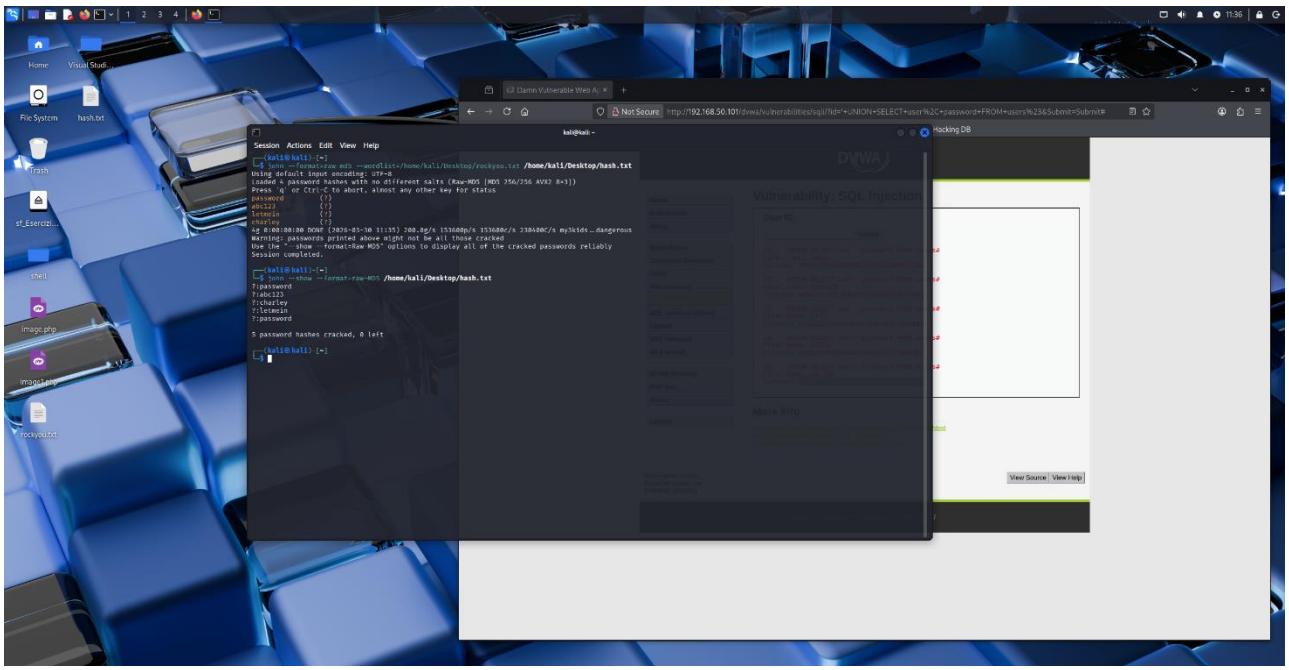
Per recuperare le password in chiaro abbiamo usato John the Ripper.

Abbiamo inserito tutti gli hash in un file e lanciato il tool. Dopo poco tempo, John è riuscito a trovare diverse password.

Questo dimostra quanto sia rischioso usare MD5: anche senza grandi risorse, è possibile recuperare password reali abbastanza velocemente.







DoS e DDoS (spiegazione semplice)

Un attacco **DoS (Denial of Service)** serve a bloccare un servizio, rendendolo inutilizzabile per gli utenti. In pratica si sovraccarica il server fino a farlo smettere di rispondere.

Il **DDoS** è la stessa cosa, ma fatta da tante macchine insieme (ad esempio una botnet). Questo lo rende molto più potente e difficile da fermare.

Attacco Slowloris

Successivamente abbiamo utilizzato Slowloris per simulare un attacco DoS.

Questo tool funziona in modo particolare:

- apre tante connessioni verso il server
- invia richieste HTTP incomplete
- mantiene le connessioni aperte il più possibile

In questo modo il server tiene occupate tutte le sue risorse e non riesce più a gestire nuove richieste.

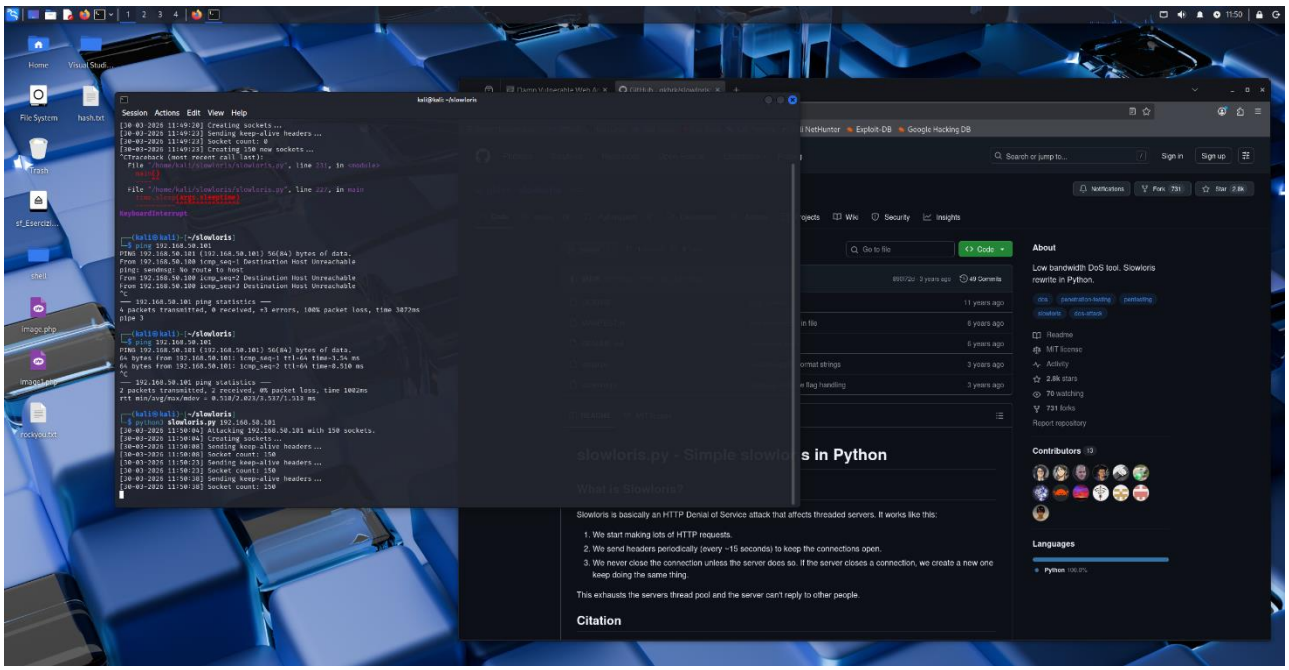
La cosa interessante è che Slowloris non usa molta banda, quindi è difficile da rilevare rispetto ad altri attacchi più “rumorosi”.

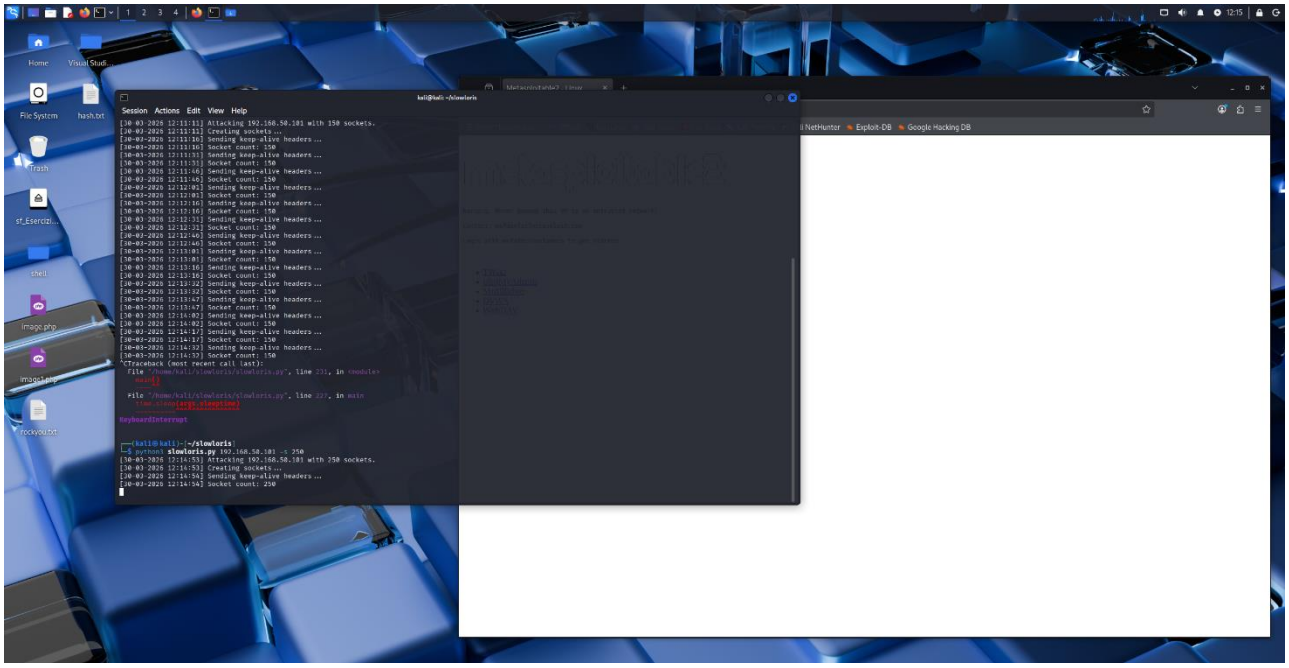
Esecuzione dell’attacco

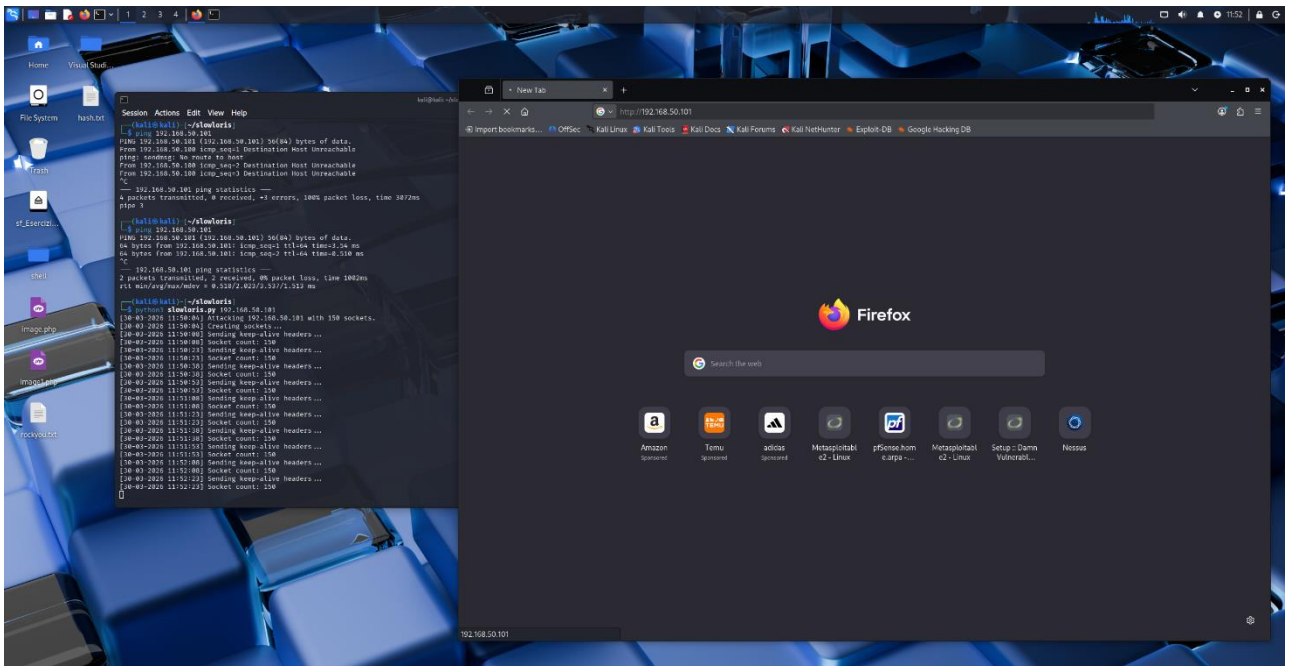
Abbiamo lanciato Slowloris dalla macchina Kali verso Metasploitable.

Dopo poco tempo si è visto chiaramente l’effetto:

- il sito diventava sempre più lento
- alcune richieste fallivano
- a un certo punto il server smetteva di rispondere







Monitoraggio con watch e curl

Per controllare meglio la situazione abbiamo usato questo comando:

watch -n 1 "curl -I http://ip-metasploitable"

Questo ci ha permesso di vedere ogni secondo lo stato del server.

All’inizio tutto funzionava normalmente (HTTP 200 OK), ma durante l’attacco:

- i tempi di risposta aumentavano
- comparivano errori
- a volte non arrivava nessuna risposta

È stato molto utile per vedere in tempo reale l'impatto dell'attacco.

Conclusioni

Questa esercitazione è stata utile perché ha mostrato concretamente alcune debolezze comuni:

- gli hash MD5 sono facilmente craccabili
- una SQL Injection può esporre dati molto sensibili
- un attacco DoS può mettere offline un servizio anche senza grandi risorse